

ПРАКТИЧЕСКАЯ РАБОТА № 7.1

Тема: Технологии управления доступом: идентификация и аутентификация. Управление потоками информации

Программное обеспечение:

1. ISO образ ОС Win 7 <https://www.microsoft.com/ru-ru/download/details.aspx?id=47591> или ISO образ Ubuntu 16.04 <https://releases.ubuntu.com/16.04/> и ISO образ CentOS 7 https://buildlogs.centos.org/rolling/7/isos/x86_64/
2. Dallas Lock (расположен в папке PRZ_7.1_distr) https://drive.google.com/drive/folders/1pI05mNARqJl0U5WMY2vQZdpFk9GwC_KP?usp=sharing
3. Games Class (расположен в папке PRZ_7.1_distr) https://drive.google.com/drive/folders/1pI05mNARqJl0U5WMY2vQZdpFk9GwC_KP?usp=sharing
4. Run Pad Shell 6.95 (расположен в папке PRZ_7.1_distr) https://drive.google.com/drive/folders/1pI05mNARqJl0U5WMY2vQZdpFk9GwC_KP?usp=sharing

Вопросы для обсуждения:

1. Какие технологии управления доступом существуют?
2. В чем разница дискреционного и мандатного управления доступа?
3. В операционной системе Windows какие технологии управления доступом применяются?
4. Приведите пример программы с мандатным управлением доступа?
5. Приведите пример программы, реализующие модель RBAC?
6. В чем разница таблицы разрешений и списков контроля доступа?
7. Какие виды административного доступа Вы знаете?
8. Что такое RADIUS?
9. В каких случаях применяется RADIUS?
10. В каких случаях применяется TACACS+?
11. Что обеспечивает подотчетность?

12. Какие группы событий и действий могут быть выявлены и журналированы?

13. Какие инструменты анализа журналов регистрации событий существуют?

14. Для каких целей необходим мониторинг нажатия клавиш?

Цель: Получение теоретических и практических навыков применения технологий идентификации и аутентификации.

Основные теоретические сведения

1. Технологии управления доступом

Управление доступом – это механизм безопасности, который управляет процессом взаимодействия пользователей с системами и ресурсами, а также систем между собой. Этот механизм защищает системы и ресурсы от несанкционированного доступа и принимает участие в определении уровня авторизации после успешного прохождения процедуры аутентификации.

Для получения доступа к объекту пользователю необходимо выполнить четыре шага, представленные на рисунке 1.

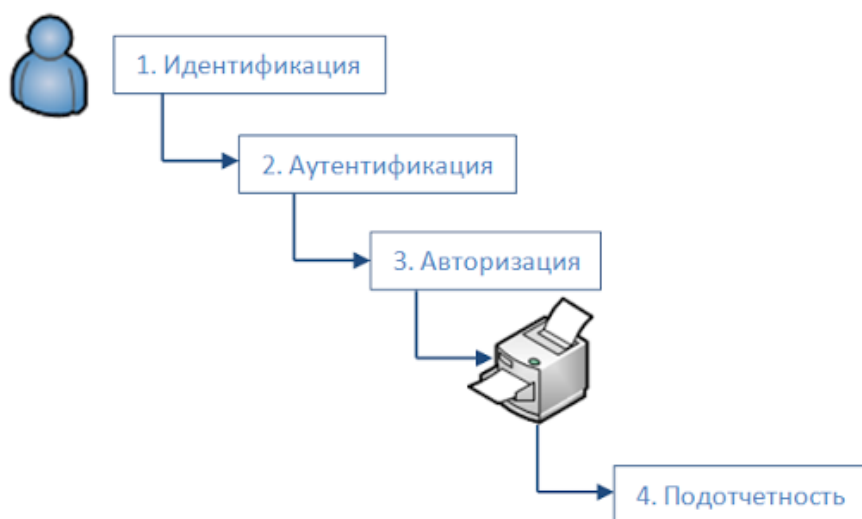


Рисунок 1 – Четыре шага для доступа субъекта к объекту: идентификация, аутентификация, авторизация и подотчетность

Идентификация – это метод проверки, подтверждающий, что субъект (пользователь, программа или процесс) – тот, за кого себя выдает. После

прохождения *идентификации* (посредством некоего идентификатора, например, логина), пользователь должен быть аутентифицирован. Это означает, что он должен доказать, что он является тем, кем представляется. Аутентификация, как правило, включает в себя два этапа: ввод публичной информации (имя пользователя, идентификатор, номер счета и т.п.), а затем ввод секретной информации (постоянный пароль, смарт-карта, одноразовый пароль, PIN-код, электронно-цифровая подпись и т.п.). После успешной аутентификации, система должна выяснить, уполномочен ли пользователь на доступ к определенному ресурсу и какие действия с этим ресурсом он может выполнять.

Авторизация является одним из основных компонентов любой операционной системы, аналогичную функциональность могут предоставлять различные приложения, дополнительные пакеты безопасности и сами ресурсы. Когда пользователь, после прохождения процедуры аутентификации, хочет обратиться, например, к таблице на файловом сервере, этот сервер проверяет, имеет ли пользователь доступ к этой таблице. Сервер также проверяет, может ли пользователь изменить, удалить, переместить или скопировать файл с таблицей.

Модель управления доступом – это структура, которая определяет порядок доступа субъектов к объектам. Для реализации правил и целей этой модели используются технологии управления доступом и механизмы безопасности. Существует три основных модели управления доступом: дискреционная, мандатная и не дискреционная (также называемая ролевой). Каждая модель использует различные методы для управления доступом субъектов к объектам, каждая имеет свои преимущества и ограничения. Выбор оптимальной модели управления доступом следует производить на основе целей бизнеса и целей безопасности компании, а также на основе ее культуры и стиля управления бизнесом.

Эти модели встроены в ядро различных ОС и во многих случаях поддерживаются приложениями. Каждая ОС система имеет ядро

безопасности, которое реализует концепцию монитора обращений (referencemonitor), которая зависит от встроенной в систему модели управления доступом. Для каждой попытки доступа перед тем, как субъект сможет начать взаимодействовать с объектом, ядро безопасности проверяет правила модели управления доступом, чтобы определить, является ли запрос допустимым.

1.1. Дискреционное управление доступом

Если пользователь создает файл, он является владельцем этого файла. Идентификатор этого пользователя размещается в заголовке файла. Владение может быть также предоставлено определенному человеку. Система, которая использует дискреционное (избирательное) управление доступом (DAC – Discretionary Access Control) позволяет владельцу ресурса определять, какие субъекты могут использовать этот ресурс. Эта модель называется дискреционной (избирательной), т.к. управление доступом основано на решениях владельца. Часто руководители подразделений являются владельцами данных в рамках своих подразделений. Будучи владельцами, они могут решать, кому следует, а кому не следует иметь доступ к этим данным.

В модели DAC ограничения доступа основываются на авторизации пользователя. Это означает, что владельцы могут определять, какой тип доступа может быть разрешен к их объектам. Если компания использует модель DAC, сетевой администратор может разрешить владельцам ресурсов управлять доступом пользователей к своим ресурсам. Чаще всего модель DAC реализуется посредством списков контроля доступа (ACL), содержимое которых определено владельцами. Работа ACL реализуется средствами операционной системы. Это может позволить пользователям использовать информацию динамически вместо более статичного мандатного или ролевого управления доступом. Большинство операционных систем основаны на модели DAC (например, системы Windows, Linux, Macintosh и большинство систем *nix).

DAC может быть применен как к древовидной структуре директорий, так и к файлам, которые в них содержатся и использует следующие разрешения доступа:

- «Нет доступа» (NoAccess),
- «Чтение» (Read),
- «Запись» (Write),
- «Выполнение» (Execute),
- «Удаление» (Delete),
- «Изменение» (Change),
- «Полный доступ» (Full Control).

1.2. Мандатное управление доступом

В модели мандатного управления доступом (MAC – Mandatory Access Control) пользователи и владельцы данных не могут самостоятельно определять, кто может иметь доступ к файлам. Окончательное решение принимает операционная система, и это решение может не совпадать с желаниями пользователя. Эта модель является более структурированной и жесткой, она основана на системе меток безопасности (securitylabel). Пользователи получают уровни допуска (секретно, совершенно секретно, конфиденциально и т.д.), таким же способом классифицируются данные. Допуски и классы данных сохраняются в метках безопасности и являются границами для субъектов и объектов. Когда система принимает решение в процессе выполнения запроса на доступ к объекту, она основывается на уровне допуска субъекта, классификации объекта и политике безопасности системы. Правила доступа субъектов к объектам разрабатываются офицером безопасности, настраиваются администратором, реализуются операционной системой и поддерживаются технологиями безопасности.

Метки безопасности прикрепляются ко всем объектам, каждый файл, директория, устройство имеют свою метку безопасности, содержащую информацию о классе их информации. Например, если пользователь имеет уровень допуска «Секретно», а запрашивает информацию класса

«Совершенно секретно», он получит отказ, поскольку его допуск не равен (и не выше) классификации.

Каждый субъект и объект всегда должен иметь связанную с ним метку с атрибутами, поскольку это является частью критериев принятия решения операционной системой.

Эта модель применяется в среде, в которой классификация информации и конфиденциальность чрезвычайно важны, например, в военных организациях. На базе этой модели разработаны специализированные версии Unix-систем, например, Astra Linux, «Циркон». Компании не могут просто переключаться между использованием DAC и MAC. Им потребуется специально приобрести для этого операционную систему, спроектированную и реализующую правила MAC. Системы DAC не понимают меток безопасности, классификации, уровней допуска и поэтому не могут применяться в организациях, которым нужна такая структура управления доступом.

1.3. Ролевое управление доступом

Модель ролевого управления доступом (RBAC – Role-based Access Control), также называемая не дискреционным управлением доступом (Nondiscretionary Access Control), использует централизованно администрируемый набор контролей, предназначенных для определения порядка взаимодействия субъекта с объектом. Этот тип модели разрешает доступ к ресурсам, основываясь на роли пользователя в компании. Это называют не дискреционным подходом, поскольку назначение пользователю роли является неизбежным.

Более традиционное администрирование прав доступа основано на модели DAC, в которой управление доступом происходит на уровне объекта с использованием ACL. Этот подход более сложен, т.к. администратор должен перевести организационную политику компании в разрешения при настройке ACL. С ростом количества объектов и пользователей в компании у многих

пользователей появляются (или остаются после изменения обязанностей) права доступа к некоторым ресурсам, которые им не требуются для работы. Это нарушает принцип минимальных привилегий и увеличивает риски компании. Подход RBAC позволяет избежать этого, так как разрешения управляются на уровне должностных ролей. В модели RBAC роль определяется в терминах операций и задач, которые она выполняет, тогда как в модели DAC описывается, какие субъекты могут иметь доступ к каким объектам.

Модель RBAC лучше всего подходит для компаний с большой «текучестью» кадров. Если увольняется сотрудник, которому была назначена определенная роль, то новому сотруднику, который займет его место, просто назначается та же роль. Таким образом, администратору не нужно постоянно вносить изменения в ACL отдельных объектов. Ему достаточно создать определенные роли, настроить необходимые этим ролям права и разрешения, а затем назначить пользователям эти роли.

Это надежная модель, поскольку она может включать другие компоненты в процесс принятия решений о возможности доступа, а не просто основываться на учетных данных. Например, система RBAC может учитывать время дня, местоположение роли, день недели и т.д.

Иерархический RBAC

Этот компонент позволяет администратору создать организационную модель RBAC на основе организационной структуры и функциональных разграничений, требующихся в конкретной среде. Это очень полезно, поскольку в компаниях уже есть иерархические структуры персонала. Чаще всего, чем выше вы находитесь в организационной иерархии компании, тем больше прав доступа вы имеете.

2. Техника управления доступом

2.1. Управление доступом на основе правил

Управление доступом на основе правил (Rule-based Access Control) использует определенные правила, указывающие на то, что субъект может и что не может делать с объектом. Это основано на простых правилах (типа, «если X – то Y»), которые могут использоваться для обеспечения более детального управления доступом к ресурсам. Чтобы субъект получил доступ к объекту, должен быть выполнен набор предустановленных правил. Эти правила могут быть простыми и прямолинейными (например, «если идентификатор пользователя соответствует аналогичному идентификатору в предъявленном им цифровом сертификате, пользователю разрешается доступ»), либо может использоваться целый ряд сложных правил, которые должны быть выполнены, чтобы пользователь получил доступ к объекту (например, «если пользователь входит в систему с понедельника по пятницу и между 9:00 и 18:00, если допуск безопасности пользователя равен или превышает класс объекта, если пользователь имеет необходимую категорию «должен знать», тогда пользователю разрешается доступ»). Управление доступом на основе правил не обязательно основано на идентификации. Например, правило, что вложение в электронном сообщении не должно превышать 5МВ, действует на всех пользователей, независимо от их идентификатора. Однако это же правило можно связать с конкретными пользователями, индивидуально установив для них максимальный объем вложения, но это гораздо менее удобно и более трудоемко. Использование правил, затрагивающих всех пользователей, позволяет упростить управление доступом.

Управление доступом на основе правил позволяет разработчикам подробно описать конкретные ситуации, в которых субъект может (или не может) получить доступ к объекту, а также определить, что субъект сможет делать с объектом, получив к нему доступ. Традиционно управление доступом на основе правил используется в системах, использующих модель МАС, в качестве механизма ее реализации. Однако в настоящее время он используется и в других системах и приложениях. Примером могут быть системы

контентной фильтрации, кроме того, управление доступом на основе правил часто используется в межсетевых экранах и маршрутизаторах.

2.2. Ограниченный пользовательский интерфейс

Ограниченный пользовательский интерфейс (constrained user interface) ограничивает возможности доступа пользователей к отдельным функциям, информации или отдельным системным ресурсам. Существует три основных типа ограниченных интерфейсов:

- меню и оболочки (shell);
- представления (view) баз данных;
- физически ограниченные интерфейсы.

При использовании ограниченного меню и оболочки пользователи видят только те команды, которые они могут использовать. Например, если администратор хочет, чтобы пользователи могли запускать только одну программу, именно одна эта программа должна отображаться в меню выбора. Это ограничивает доступную пользователям функциональность. Оболочка – это разновидность виртуальной среды системы, ее пользовательский интерфейс, командный интерпретатор. Ограниченная оболочка содержит только те команды, которые администратор хочет сделать доступными пользователям.

Часто администраторы баз данных настраивают базы данных так, чтобы пользователи не видели непосредственно поля, содержащие конфиденциальную информацию. Доступ пользователей к данным, содержащимся в базах данных, ограничивается с помощью представлений. Например, если администратор базы данных хочет, чтобы руководители видели график рабочего времени своих сотрудников, но не информацию об их заработной плате, они просто запрещают доступ к полям с информацией о заработной плате для данного типа пользователей. Аналогично, когда сотрудники бухгалтерии, занимающиеся начислением заработной платы,

будут просматривать ту же базу данных, им, наоборот, должна быть доступна информация о заработной плате, но не данные о графике рабочего времени.

Пример проиллюстрирован на рисунке 2.

Иванов И.	50 000 р.	9:00 – 18:00
Петров П.	65 000 р.	9:00 – 18:00
Сидоров С.	20 000 р.	9:00 – 14:00

Кадровая база данных

Иванов И.	9:00 – 18:00
Петров П.	9:00 – 18:00
Сидоров С.	9:00 – 14:00

Представление для руководителей

Иванов И.	50 000 р.
Петров П.	65 000 р.
Сидоров С.	20 000 р.

Представление для бухгалтерии

Рисунок 2 – Различия между представлениями базы данных и самой базой данных.

Физически ограниченный интерфейс может быть реализован посредством предоставления пользователю специальной клавиатуры, имеющей ограниченный набор клавиш, или ограниченного набора экранных кнопок на сенсорном экране (примером может быть интерфейс банкомата или терминала для приема платежей).

2.3. Матрица контроля доступа

Матрица контроля доступа (access control matrix) – это таблица субъектов и объектов, содержащая информацию о том, какие действия конкретные субъекты могут делать с конкретными объектами. На рисунке 3 показан пример матрицы контроля доступа.

Пользователь	Файл 1	Файл 2	Файл 3
Диана	Чтение и Выполнение	Чтение, Запись и Выполнение	Нет доступа
Кэти	Чтение и Выполнение	Чтение	Нет доступа
Крис	Чтение, Запись и Выполнение	Чтение и Выполнение	Чтение
Джон	Чтение и Выполнение	Нет доступа	Чтение и Запись

Рисунок 3 – Пример матрицы контроля доступа

Этот тип управления доступом обычно используется в качестве атрибутов в моделях DAC. Права доступа могут быть напрямую назначены субъектам (разрешения) или объектам (ACL).

Таблицы разрешений

Таблицы разрешений (capability tables) указывают права доступа определенного субъекта к определенным объектам. Таблицы разрешений отличаются от ACL: таблицы разрешений являются ограничением для субъектов, а ACL – для объектов. Разрешения соответствуют строке субъекта в матрице контроля доступа. В таблице 2-1 разрешениями Дианы являются: Файл 1 (Чтение и Выполнение), Файл 2 (Чтение, Запись и Выполнение) и Файл 3 (Нет доступа). Пример системы, основанной на таблицах разрешений – Kerberos. В этой среде пользователь получает билет со своей таблицей разрешений. Билет является границами доступа пользователя и указывает, к каким объектам пользователь может иметь доступ и насколько времени. Управление доступом основано на этом билете (или таблице разрешений). На рисунке 4 показаны различия между таблицей разрешений и ACL. Разрешения могут реализовываться в форме токена, билета или ключа. Когда субъект предоставляет свой компонент разрешений, операционная система (или приложение) просматривает права доступа и операции, описанные в нем, и разрешает субъекту выполнять только соответствующие функции. Компонент разрешений – это структура данных, содержащая уникальный идентификатор объекта и права доступа субъекта к объекту. Объектом может быть файл, массив, сегмент памяти или порт. Каждый пользователь, процесс, приложение имеет свой список разрешений.

Матрица контроля доступа					
Разрешения	Субъект	Файл 1	Файл 2	Файл 3	Файл 4
	Ларри	Чтение	Чтение, Запись	Чтение	Чтение, Запись
	Дэвид	Полный доступ	Нет доступа	Полный доступ	Чтение
	Мо	Чтение, Запись	Нет доступа	Чтение	Полный доступ
	Боб	Полный доступ	Полный доступ	Нет доступа	Нет доступа
				ACL	

Разрешения = строка в матрице
ACL = столбец в матрице

Рисунок 4 – Таблица разрешений ограничивает субъект, а ACL ограничивает объект

Списки контроля доступа

Списки контроля доступа (ACL – access control list) используются во многих операционных системах, приложениях и маршрутизаторах. Это

списки субъектов, которым разрешен доступ к определенному объекту, с указанием уровня разрешенного доступа. Разграничение доступа может выполняться на уровне пользователей или на уровне групп.

ACL являются отображением значений матрицы контроля доступа на отдельный объект. Тогда как разрешения являются строкой в матрице контроля доступа, ACL соответствует столбцу в этой матрице.

2.4 Контентно-зависимое управление доступом

В системе контентно-зависимого управления доступом (content-dependent access control) доступ к объекту определяется на основании содержимого самого объекта. Например, содержимое поля базы данных может указывать, какие пользователи могут иметь к нему доступ. Контентно-зависимая фильтрация используется в корпоративных фильтрах электронной почты, которые ищут в тексте сообщения определенные строки (например, «конфиденциально», «номер паспорта», «совершенно секретно» и другие словосочетания, которые компания считает подозрительными). Также компании используют это для контроля доступа в Интернет, аналогичным образом отслеживая в трафике определенные слова, например, с целью выявления сотрудников, играющих в азартные игры или занимающихся поиском работы.

2.5 Контекстно-зависимое управление доступом

Контекстно-зависимое управление доступом (context-dependent access control) отличается от контентно-зависимого, при контекстно-зависимом управлении доступом решение о возможности доступа принимается не на основе критичности данных, а на основе контекста собранной информации. Система, использующая контекстно-зависимое управление доступом, сначала «анализирует ситуацию», а затем принимает решение о возможности доступа. Например, ряд межсетевых экранов может принимать контекстно-зависимое решение, собрав информацию о состоянии пакета перед тем, как пропустить

его в сеть. Межсетевой экран с контролем состояния (state full firewall) «знает» необходимые шаги для коммуникаций по определенным протоколам и проверяет, что они были соблюдены. Например, при использовании соединения TCP, отправитель отправляет пакет SYN, получатель отправляет SYN/ACK, и затем отправитель направляет пакет ACK (подтверждение). Межсетевой экран с контролем состояния понимает эти шаги и не пропускает пакеты, нарушающие эту последовательность. Если, к примеру, такой межсетевой экран получает SYN/ACK, однако перед ним не было соответствующего (в рамках этого соединения) пакета SYN, межсетевой экран понимает, что это неправильно и уничтожает этот пакет. Это пример контекстно-зависимого управления доступом – в нем межсетевой экран учитывает контекст при принятии решения о возможности доступа.

3. Администрирование доступа

После разработки политики безопасности, выбора типа модели управления доступом (DAC, MAC или ролевое) и внедрения техники управления доступом (матрицы контроля доступа, ограниченные интерфейсы, контекстно- или контентно-зависимое управление, управление на основе правил) необходимо определить, каким образом будет администрироваться выбранная модель управления доступом. Существует два основных варианта администрирования управления доступом: централизованный и децентрализованный. При принятии решения необходимо понимать оба подхода, чтобы выбирать из них именно тот, который позволит обеспечить необходимый уровень безопасности.

3.1 Централизованное администрирование управления доступом

При централизованном администрировании доступа (centralized access control administration) один субъект (человек или подразделение) следит за доступом ко всем корпоративным ресурсам. Этот субъект (администратор безопасности) настраивает механизмы, которые реализуют управление

доступом, выполняет изменения пользовательских профилей, отзывает права доступа при необходимости, полностью блокирует доступ пользователя в случае его увольнения. Этот тип администрирования предоставляет последовательные и унифицированные методы управления правами доступа пользователей. Он обеспечивает строгий контроль данных, т.к. только один человек (или подразделение) имеет необходимые права для изменения профилей доступа и разрешений, однако это довольно медленный способ, поскольку все изменения должны быть выполнены одним человеком (подразделением).

Для централизованного удаленного управления доступом применяются протоколы аутентификации называют AAA-протоколами (аутентификация, авторизация и аудит) которые приведены ниже.

RADIUS (remote authentication dial-in user service) – это сетевой протокол, который обеспечивает клиент-серверную аутентификацию, авторизацию и аудит удаленных пользователей. Для подключения удаленных пользователей, в сети должны быть установлены серверы доступа и средства для удаленного подключения (например, модемный пул, DSL, ISDN или линия T1). Сервер доступа запрашивает у пользователя учетные данные для входа и передает их на сервер RADIUS, на котором хранятся имена пользователей и пароли. При этом удаленный пользователь является клиентом сервера доступа, а сервер доступа является клиентом RADIUS-сервера.

В настоящее время большинство интернет-провайдеров используют RADIUS для аутентификации клиентов перед тем, как разрешить им доступ к сети Интернет. Сервер доступа и программное обеспечение клиента «договариваются» о протоколе аутентификации, который они будут использовать (PAP, CHAP или EAP), посредством процедуры «рукопожатия» (handshake), после чего клиент передает серверу доступа свое имя пользователя и пароль. Это взаимодействие происходит через соединение PPP. Взаимодействие сервера доступа с RADIUS-сервером осуществляется по протоколу RADIUS. Сервер доступа уведомляет RADIUS-сервер о фактах

начала и окончания сеанса в целях предоставленных тарификации услуг (биллинга).

RADIUS также используется в корпоративных средах, чтобы обеспечить доступ к корпоративной сети сотрудникам во время командировок или из дома. RADIUS позволяет компаниям хранить профили пользователей в централизованной базе данных. После успешной аутентификации, внешнему пользователю присваивается предварительно настроенный профиль, определяющий к каким ресурсам он может получить доступ, а к каким – нет. Эта технология позволяет компании иметь единую управляемую точку входа, что обеспечивает стандартизацию с точки зрения безопасности и предоставляет простой способ контроля использования удаленного доступа и сбора сетевой статистики. Пример использования протокола RADIUS показан на рисунке 5.

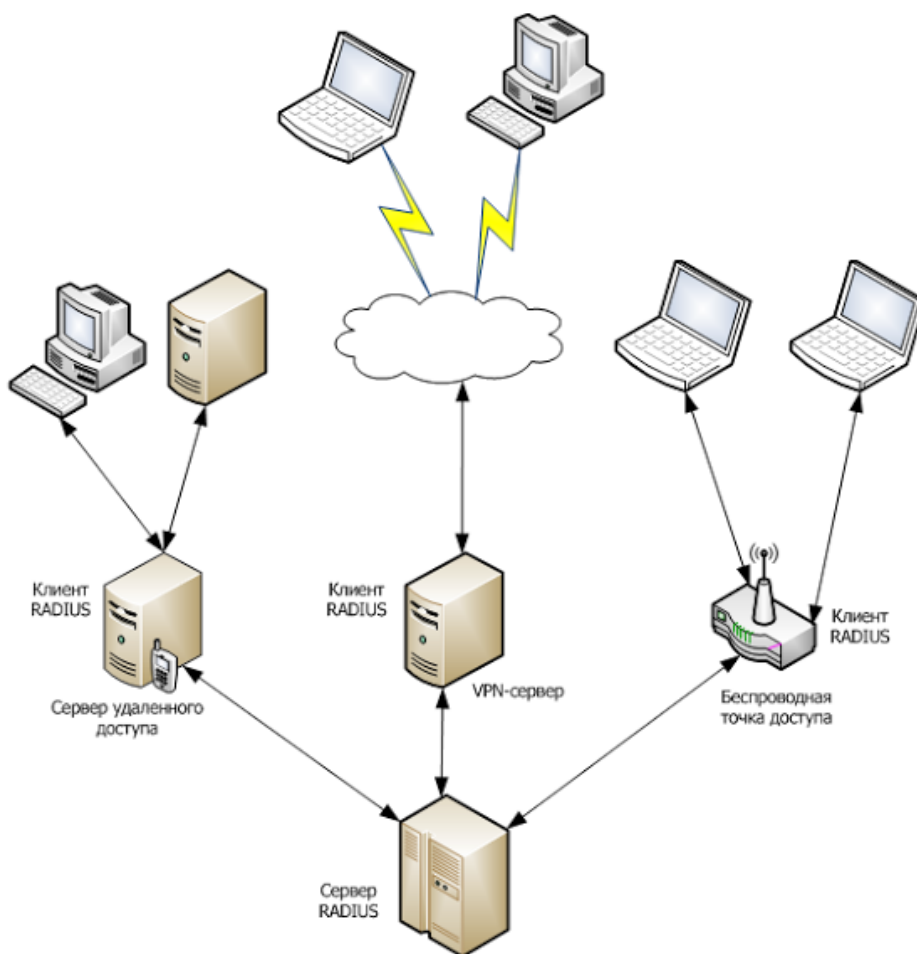


Рисунок 5 – Пример реализации протокола RADIUS

TACACS (Terminal Access Controller Access Control System) прошел через три поколения: TACACS, Extended TACACS (XTACACS) и TACACS+. TACACS объединяет процессы аутентификации и авторизации, XTACACS разделяет процессы аутентификации, авторизации и аудита, а TACACS+ – это XTACACS с расширенной двухфакторной аутентификацией пользователей. TACACS использует постоянные пароли для аутентификации, а TACACS+ позволяет использовать динамические (одноразовые) пароли, обеспечивая более высокий уровень безопасности.

TACACS+ реализует в основном ту же функциональность, что и RADIUS с некоторыми отличиями. Во-первых, TACACS+ использует в качестве транспорта протокол TCP вместо протокола UDP в RADIUS, и поэтому ему не требуется дополнительный код для обнаружения и исправления ошибок передачи сетевых пакетов. Во-вторых, TACACS+ шифрует всю информацию (включая имя пользователя, данные учета и авторизации), а RADIUS шифрует только пароль пользователя, позволяя злоумышленнику перехватить важную информацию. В-третьих, TACACS+ использует настоящую архитектуру AAA, обеспечивая дополнительную гибкость при настройке процесса аутентификации удаленных пользователей, тогда как RADIUS объединяет функциональность аутентификации и авторизации.

TACACS позволяет настроить работу удаленных и локальных пользователей через одну базу данных. Разделение функциональности аутентификации, авторизации и учета позволяет сделать это. TACACS+ также позволяет сетевому администратору настроить более детальные профили пользователей, указывая реальные команды, которые пользователи могут выполнять. Пример реализации клиент-серверной модели через протокол TACACS+ представлен на рисунке 6.

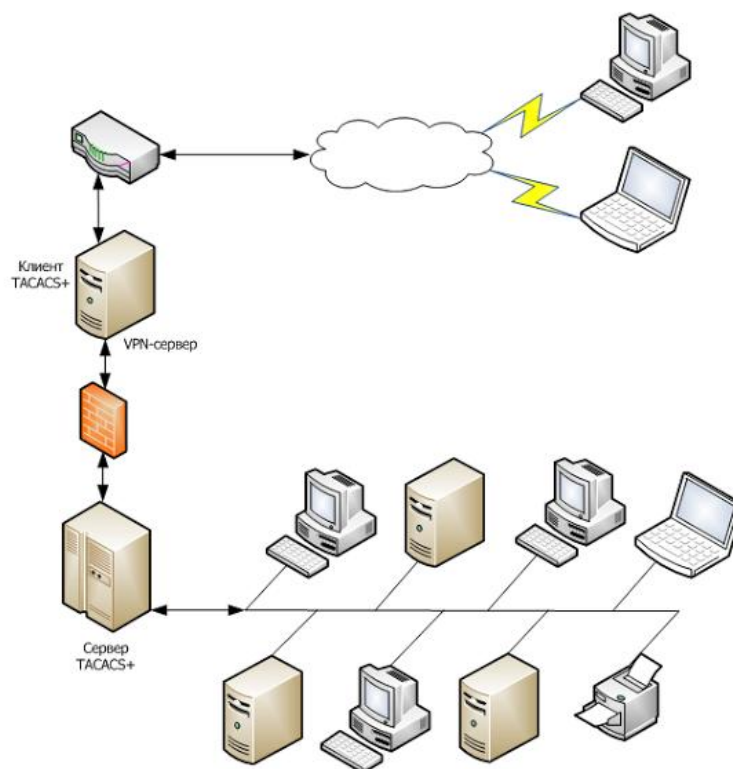


Рисунок 6 – TACACS+ работает в рамках клиент-серверной модели

RADIUS и TACACS+ являются протоколами, а протоколы являются не более чем согласованным способом взаимодействия. Когда RADIUS-клиент связывается с RADIUS-сервером, он делает это посредством протокола RADIUS, который на самом деле представляет собой некий набор полей, в которые записываются некоторые значения. Эти поля называют парами атрибут-значение (AVP – attribute-value pair). В качестве аналогии, предположим, что я посылаю вам пустой бланк, на котором есть несколько пустых строк, каждая из которых имеет название: фамилия, имя, цвет волос, размер обуви. Вы заполняете эти строки соответствующими значениями и отправляете заполненный бланк обратно мне. В общем виде, именно так работают протоколы: отправляющая система просто заполняет поля необходимой для принимающей системы информацией, которая затем извлекает ее и обрабатывает.

TACACS+ имеет больше AVP, что обеспечивает более детальный контроль того, что могут и что не могут делать пользователи, а также позволяет сетевому администратору определять списки ACL, фильтры,

привилегии пользователей и многое другое. На рисунке 7 показаны различия между RADIUS и TACACS+.

	RADIUS	TACACS+
Передача пакетов	UDP	TCP
Шифрование пакетов	Шифруется только пароль при передаче от RADIUS-клиента к серверу.	Шифруется весь трафик между клиентом и сервером.
Поддержка AAA	Объединяет сервисы аутентификации и авторизации.	Использует архитектуру AAA, разделяя аутентификацию, авторизацию и аудит.
Поддержка протоколов	Работает через соединение PPP.	Поддерживает другие протоколы, такие как AppleTalk, NetBIOS и IPX.
Ответы	Использует единственный запрос-ответ при аутентификации пользователя, который используется для всех действий AAA.	Использует множество запросов-ответов для каждого процесса AAA. Каждое действие AAA должно быть аутентифицировано.

Рисунок 7 – Отдельные различия между двумя AAA-протоколами

Таким образом, RADIUS является подходящим протоколом, если используется упрощенная аутентификация по имени пользователя и паролю, и системе нужно только решить, разрешать доступ пользователю или нет (как, например, для работы интернет-провайдера). TACACS+ лучше подходит для сред, в которых требуется более надежная аутентификация и жесткий контроль более сложных действий по авторизации (как, например, в корпоративных сетях).

Diameter – это протокол, разработанный на базе функциональности RADIUS, устраняющий многие из его ограничений. Предоставляет такую же функциональность, как RADIUS и TACACS+, но является более гибким и отвечающий современным требованиям. Одно время все удаленные подключения осуществлялись по протоколам PPP и SLIP, а аутентификация пользователей производилась через PAP или CHAP. Но сегодня технологии стали значительно сложнее, появилось множество различных устройств и протоколов, между которыми можно выбирать. Для аутентификации беспроводных устройств и смартфонов в нашей сети, мы используем протоколы роуминга, мобильные IP, PPP через Ethernet, голос через IP (VoIP) и т.п. Традиционные AAA-протоколы не могут работать со всем этим. Поэтому был разработан новый AAA-протокол Diameter, который решает эти проблемы, а также многие другие.

Протокол Diameter состоит из двух частей. Первая часть – это базовый протокол, который обеспечивает безопасное взаимодействие между участниками Diameter, определение характеристик и соглашение о версии. Вторая является расширением, которое надстроено над базовым протоколом. Эта часть позволяет различным технологиям использовать Diameter для аутентификации.

Мобильный IP. Эта технология позволяет пользователю перемещаться из одной сети в другую и при этом продолжать использовать один и тот же IP-адрес. Это усовершенствование протокола IP, которое позволяет пользователю иметь свой домашний IP-адрес, связанный с его домашней сетью, и обслуживающий адрес (care-ofaddress). Обслуживающий адрес меняется при перемещении из одной сети в другую. Весь трафик, адресованный на домашний IP-адрес пользователя, перенаправляется на его обслуживающий адрес.

До появления концепции Diameter, в IETF были отдельные рабочие группы, которые определяли порядок работы протоколов VoIP (голос через IP), FoIP (факс через IP), Мобильный IP, а также протоколов удаленной аутентификации. Внедрение их по отдельности в любой сети легко может привести к целому ряду сложностей, включая проблемы совместимости. Это требует от клиентов развертывать и настраивать несколько серверов с различными политиками и увеличивает стоимость каждого нового дополнительного сервиса. Diameter предоставляет базовый протокол, который определяет формат заголовков, параметры безопасности, команды и AVP. Этот базовый протокол позволяет связать расширения с другими сервисами, такими как VoIP, FoIP, Мобильный IP, аутентификацию беспроводных устройств и мобильных телефонов. Таким образом, Diameter может использоваться в качестве AAA-протокола во всех этих случаях.

В качестве аналогии, рассмотрим ситуацию, в которой десяти сотрудникам одной компании нужно попасть на работу. Они могут ездить на работу на своих автомобилях по своим маршрутам, но это потребует

дополнительную территорию для организации стоянки, а также найма охранника, чтобы он стоял около ворот и пропускал только машины сотрудников компании. С другой стороны, все они могут воспользоваться автобусом компании. Автобус в данном случае является общим элементом (как базовый протокол), позволяющим всем сотрудникам (различным сервисам) попасть в одно и то же место – на работу (сетевую среду). Diameter обеспечивает общий AAA и структуру безопасности, в рамках которой могут работать различные службы, как показано на рисунке 8.

RADIUS и TACACS+ являются клиент-серверными протоколами, т.е. серверная часть не может по своей инициативе отправлять команды клиентской части. Diameter – это одноранговый (peer-based) протокол, что позволяет любой стороне инициировать взаимодействие. Функциональность позволяет серверу Diameter отправлять сообщения серверу доступа, чтобы запросить у пользователя другой набор учетных данных, если он пытается получить доступ к защищаемому ресурсу.

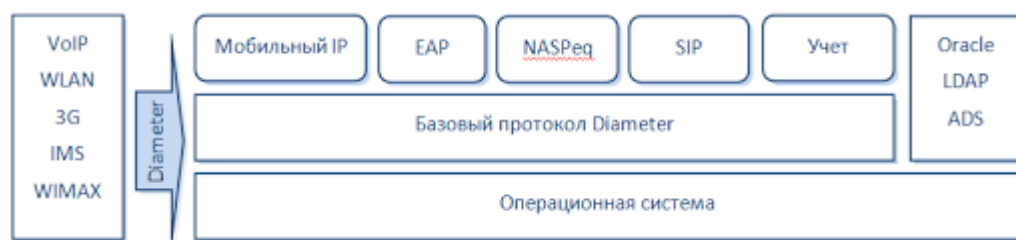


Рисунок 8 – Diameter предоставляет архитектуру AAA для различных сервисов

Diameter не является полностью обратно совместимым с RADIUS, но он предоставляет возможности для перехода с RADIUS. Diameter использует UDP и AVP, и обеспечивает поддержку работы через прокси-сервер. По сравнению с RADIUS, он лучше выявляет и исправляет ошибки, обладает повышенной отказоустойчивостью. Diameter также предоставляет сквозную (end-to-end) безопасность посредством использования IPSec или TLS, которые недоступны в RADIUS.

Diameter может предоставлять функциональность AAA другим протоколам и сервисам, поскольку имеет широкий набор AVP. RADIUS имеет 2^8 AVP, тогда как Diameter – 2^{32} . Поэтому, большее количество AVP позволяет обеспечить больше функциональности и сервисов для взаимодействия систем. Diameter предоставляет следующую функциональность AAA:

3.2 Децентрализованное администрирование управления доступом

Метод децентрализованного администрирования управления доступом (decentralized access control administration) передает управление доступом людям, которые непосредственно связаны с ресурсами и лучше понимают, кто должен и кто не должен иметь доступ к определенным файлам, данным и ресурсам. Обычно это функциональные руководители, которые предоставляют права доступа сотрудникам. Компании следует выбрать децентрализованную модель, если ее руководители имеют хорошее представление о том, какие пользователи к каким ресурсам должны иметь доступ, а также в компании отсутствуют требования о необходимости использования централизованной модели.

Управление доступом в децентрализованной модели может происходить быстрее, поскольку этим занимается больше людей в компании. Однако при этом может возникнуть конфликт интересов. Поскольку не один человек (подразделение) управляет всеми правами доступа, различные руководители и подразделения могут выполнять функции по управлению доступом и обеспечению безопасности различными способами. Это не позволит обеспечить унификацию и справедливость в рамках всей компании. Одни руководители будут слишком заняты своими ежедневными задачами и легко позволят кому угодно получить полный доступ ко всем системам своего подразделения. Другие подразделения, напротив, будут применять строгие и детальные методы управления, предоставляя сотрудникам только тот уровень доступа, который необходим им для выполнения своих задач. Кроме того, в некоторых случаях функции управления доступом будут накладываться друг

на друга, что может стать причиной того, что некоторые нежелательные действия не будут запрещены и заблокированы.

3.3 Подотчетность

Возможности аудита обеспечивают ответственность пользователей за свои действия, проверку соблюдения политики безопасности, а также могут быть использованы при проведении расследований. Есть целый ряд причин, по которым сетевые администраторы и специалисты по безопасности хотят быть уверены, что механизмы журналирования событий включены и правильно настроены: для отслеживания неправильных действий пользователей, выявления вторжений, реконструкции событий и состояния системы, предоставления материалов по запросам правоохранительных органов, подготовки отчетов о проблемах. Журналы регистрации событий хранят горы информации – не так просто «расшифровать» ее и представить в наглядном и удобном для использования виде.

Подотчетность обеспечивается отслеживаем и записью системой действий пользователя, системы и приложения. Эта запись выполняется посредством функций и механизмов, встроенных в операционную систему или приложение. Журнал регистрации событий содержит информацию о действиях операционной системы, событиях приложений, а также действиях пользователей. Этот журнал может использоваться, в том числе, для проверки правильности работы системы, выявления ошибок и условий, при которых они возникают. После критического сбоя системы сетевой администратор просматривает журналы регистрации событий, пытаясь восстановить информацию о состоянии системы в момент аварии и понять какие события могли привести к ней.

Журналы регистрации событий могут также использоваться для выдачи предупреждений в случае выявления подозрительных действий, которые могут быть расследованы позднее. Дополнительно они могут быть очень ценны при определении, как далеко зашла атака, и какие повреждения она

вызвала. Важно убедиться, что обеспечивается надлежащая защита журналов регистрации событий, гарантирующая, что любые собранные данные могут быть в случае необходимости предоставлены в неизменном виде и полном объеме для проведения расследований.

Ниже приведен обзор групп событий и действий, которые могут быть выявлены и журналированы:

События системного уровня

- Производительность системы

- Попытки регистрации пользователей (успешные и неудачные)

- Идентификатор регистрирующегося пользователя

- Дата и время каждой попытки регистрации

- Блокировка пользователей и терминалов

- Использование административных утилит

- Использование устройств

- Выполнение функций

- Запросы на изменение конфигурационных файлов

События прикладного уровня

- Сообщения об ошибках

- Открытия и закрытия файлов

- Изменения файлов

- Нарушения безопасности в рамках приложения

События пользовательского уровня

- Попытки идентификации и аутентификации

- Использование файлов, сервисов и ресурсов

- Выполнение команд

- Нарушения безопасности

Должен быть настроен порог (уровень отсечения) и параметры для каждого из этих событий и действий (например, администратор может настроить учет всех попыток регистрации, либо только неудачных). В

качестве счетчиков производительности может использоваться, к примеру, объем дискового пространства, используемого за восьмичасовой период.

Система обнаружения вторжений (IDS) должна постоянно сканировать журнал регистрации событий на предмет подозрительных действий. При выявлении нежелательных событий или событий, свидетельствующих о попытке вторжения, журналы регистрации событий должны быть сохранены, чтобы использовать их позднее в качестве улик и доказательств. Если произошло серьезное событие безопасности, система IDS должна отправить соответствующее уведомление администратору или другому персоналу, ответственному за реакцию на инциденты, для принятия оперативных мер и прекращения деструктивной деятельности. Например, если выявлена вирусная угроза, администратор может отключить почтовый сервер. Если злоумышленник получил доступ к конфиденциальной информации в базе данных, соответствующий сервер может быть временно отключен от сети или Интернета. Если атака продолжается, администратору может потребоваться проследить действия злоумышленника. IDS может показать эти действия в режиме реального времени и/или просканировать журналы регистрации событий и показать специфические последовательности (шаблоны) или поведение.

3.4. Анализ журналов регистрации событий

Журналы регистрации событий обязательно должны просматриваться и анализироваться. Это можно делать как вручную, так и с помощью автоматизированных средств. Если компания просматривает журналы вручную, необходимо систематизировать эту деятельность – что, как, когда и почему подлежит анализу. Обычно журналы регистрации событий становятся крайне востребованными после инцидента безопасности, непонятной работы системы или сбоя системы. Администратор или другой ответственный персонал пытается по-быстрому сопоставить различные действия, которые привели к этому инциденту. Такой тип анализа журналов регистрации

событий называется ориентированным на события (event-oriented). Кроме того, журналы могут просматриваться на периодической основе, чтобы выявить необычное поведение пользователей и систем, а также убедиться в исправной работе системы. При этом перед администраторами должна быть поставлена соответствующая задача периодического просмотра журналов. Для контроля журналов в режиме реального времени (или близко к этому) существуют специальные автоматизированные средства. Данные журналов регистрации событий обычно должны анализироваться, а затем сохраняться в отдельное место для хранения в течение определенного периода времени. Это должно быть отражено в политике и процедурах безопасности компании.

Анализ журналов регистрации событий вручную крайне трудоемок. Следует использовать для этого специализированные приложения и инструменты анализа, которые сокращают объем журналов и повышают эффективность ручных процедур анализа. Основное время при анализе журналов регистрации событий тратится на несущественную информацию, а эти инструменты позволяют выбирать необходимую информацию по заданным критериям и представлять ее в более наглядной и удобной форме.

Существует три основных типа инструментов анализа журналов регистрации событий:

Инструменты для уменьшения объема журналов (audit-reductiontool) отбрасывают обычные события работы программ и пользователей, записи счетчиков производительности системы, оставляя только те события, которые могут быть интересны специалистам по безопасности и администраторам

Инструменты для выявления нарушений (variance-detectiontool) отслеживают использование компьютера или ресурса, фиксируя стандартную картину, а затем выявляют отклонения от нее. Например, обычно использование ресурса происходит с 8:00 до 17:00 по рабочим дням. Факт использования этого ресурса ночью в выходной день является поводом отправки предупреждения администратору.

Инструменты выявления сигнатур атак (attacksignature-detectiontool) имеют специализированную базу данных, содержащую информацию о событиях, которые могут указывать на определенные атаки (сигнатуры атак). В журналах отыскиваются последовательности событий, соответствующие сигнатурам атак.

3.5. Мониторинг нажатия клавиш

Мониторинг нажатия клавиш (key stroke monitoring) – это вид мониторинга, позволяющий проанализировать и записать последовательность нажатий клавиш пользователем в течение сеанса его работы. При этом все символы, набранные пользователем, записываются в специальный журнал, который может быть позднее проверен. Обычно такой тип аудита используется только для выполнения специальных задач и только на короткое время, поскольку объем собранной информации будет огромен, а ее значительная часть будет неважной.

Нужно соблюдать осторожность при проведении такого мониторинга, т.к. это может нарушать законодательство. Следует заранее уведомить сотрудников о возможности такого мониторинга, а также получать разрешение руководства на его проведение. Если компания намерена использовать такой контроль, следует внести информацию об этом в политику безопасности, сообщать об этом на тренингах по вопросам безопасности, уведомить пользователей другими доступными способами о возможности такого мониторинга. Это позволит защитить компанию от претензий в нарушении неприкосновенности частной жизни, а также проинформирует пользователей об ограничениях использования рабочего компьютера в личных целях.

3.6. Защита данных аудита и журналов регистрации событий

При осуществлении атаки злоумышленник старается скрыть следы своей деятельности. Часто атакующие удаляют журналы регистрации

событий, которые содержат компрометирующую их информацию, либо удаляют из журналов регистрации событий только информацию о своем присутствии (scrubbing). Это может привести к тому, что администратор не узнает о произошедшем инциденте безопасности. Поэтому данные журналов регистрации событий должны быть защищены посредством строгого управления доступом к ним.

Только определенные лица (администраторы и персонал подразделения безопасности) должны иметь доступ на просмотр, изменение или удаление журналов регистрации событий. Никакие другие люди не должны иметь возможность просматривать данные журналы и, тем более, изменять или удалять их. Целостность этих данных может быть обеспечена средствами ЭЦП, хэш-функциями и строгим управлением доступом. Их конфиденциальность может быть защищена с помощью шифрования и управления доступом. Кроме того, целесообразно сохранять данные журналов регистрации событий на внешних носителях информации с однократной записью (например, компакт-дисках) для предотвращения потери или модификации информации. Все попытки несанкционированного доступа к журналам регистрации событий должны фиксироваться и своевременно анализироваться.

Журналы регистрации событий могут использоваться в качестве доказательств или улик, а также для демонстрации процесса атаки или подтверждения факта инцидента. Целостность и конфиденциальность этих журналов должна постоянно контролироваться.

Задания к практической работе

Часть 1

Создание новой учетной записи пользователя (рисунок 2.1):

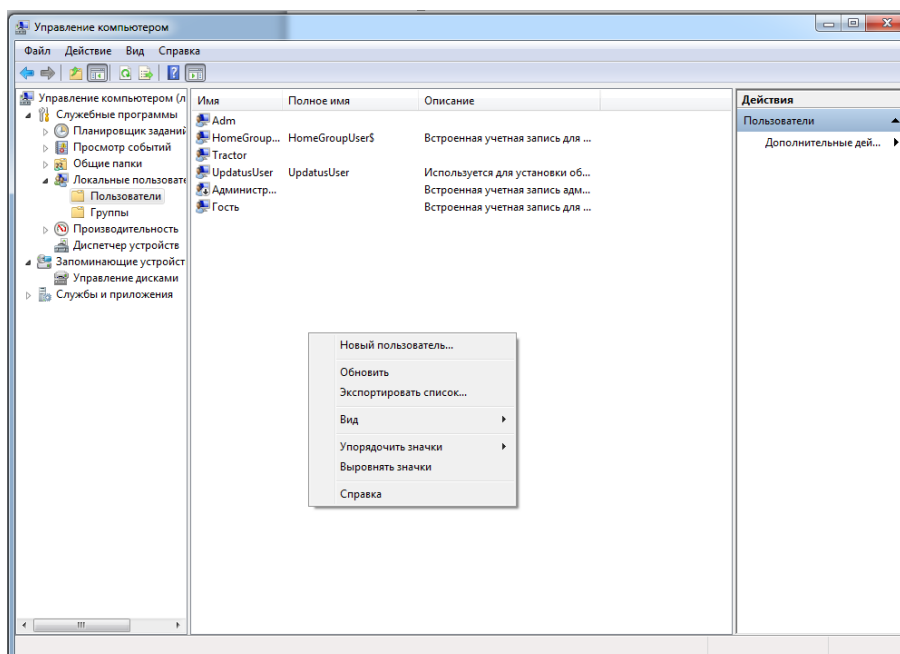


Рисунок 2.1 – Создание нового пользователя

- открыть компонент «Управление компьютером»;
- в дереве консоли выбрать компонент «Локальные пользователи и группы=> Пользователи» (compmgmt.msc);
- в окне со списком пользователей нажать правую кнопку мыши и в появившемся меню выбрать команду «Новый пользователь»;
- ввести соответствующие сведения в диалоговое окно;
- установить или снять флажки:
 - ~ Потребовать смену пароля при следующем входе в систему – при входе в систему пользователю будет выведено сообщение о смене пароля;
 - ~ Запретить смену пароля пользователем – пользователь не сможет изменять пароли других пользователей в системе;
 - ~ Срок действия пароля не ограничен – по истечению срока действия пароля, при входе в систему пользователю будет выводиться сообщение о блокировке учетной записи;
 - ~ Отключить учетную запись – вход в систему для данного пользователя будет невозможен.

- под первым пользователем из контекстного меню выбрать пункт Properties (Свойства) => Security (Безопасность);
- при помощи кнопок Add/Remove (Добавить/Удалить) настроить полномочия доступа на запрет редактирования файла/папки вторым пользователем;
- зайти в систему под вторым пользователем и постараться отредактировать файл;
- проделайте те же действия только с настройкой ACL списков Свойства => Безопасность => Дополнительно и перейдите на вкладку Владелец.

Составьте отчет о выполнении практической работы.

Включите в него копии экрана и ответы на вопросы практической работы.

Задание к практической работе

Часть 2

- создать ограниченного пользователя;
- установить пробную версию DallasLock 8.0C для настройки мандатной политики (рисунок 2.2);

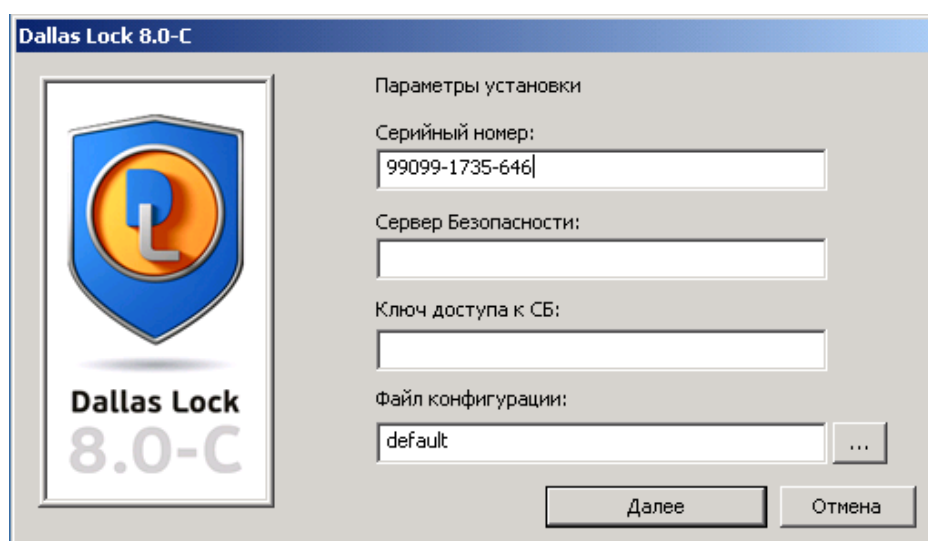


Рисунок 2.2 – Установка DallasLock 8.0C

- зайти в систему под Администратором и настроить права ограниченного пользователя (рисунок 2.3);

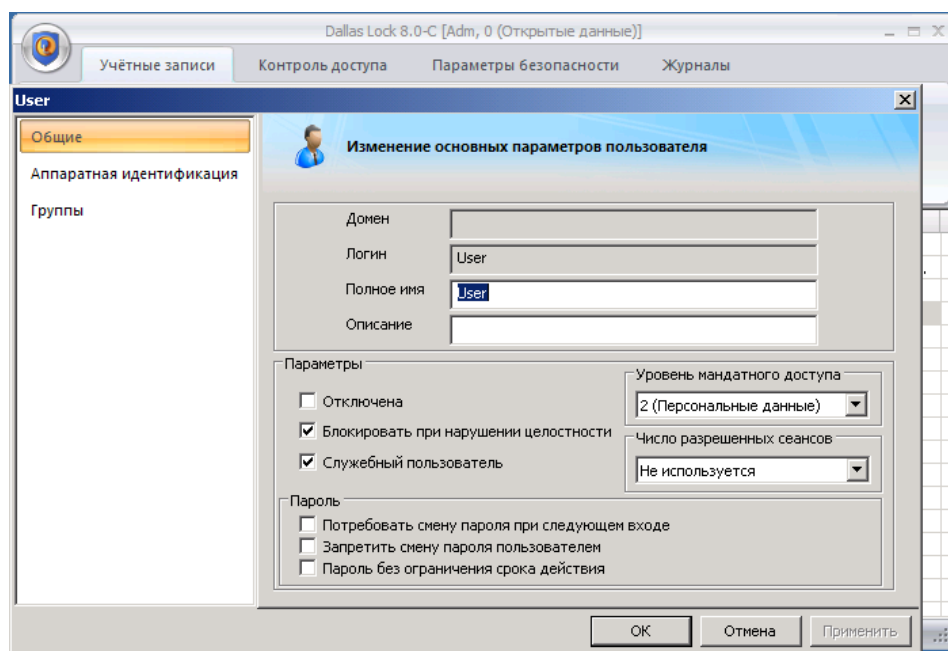


Рисунок 2.3 – Настройка прав пользователя

- после установки программы проверить возможность входа с увеличенным «Уровнем доступа»;
- создать файл с одним «Уровнем доступа» и открыть с другим «Уровнем доступа»;
- поэкспериментировать с настройками и просмотреть журналы безопасности;

Составьте отчет о выполнении практической работы.

Включите в него копии экрана пошагового выполнения задания.

Задание к практической работе

Часть 3

1. Создать копию виртуальной машины:

- выключить виртуальную машину;
- Меню => Машина => Копировать.

2. Настроить 2 машины следующим образом:

1 виртуальная машина	2 виртуальная машина
----------------------	----------------------

Имя ПК: Server Сетевой адаптер: IP: 192.168.X.1 (настройка осуществляется после загрузки ОС)	Имя ПК: Client Сетевой адаптер: IP: 192.168.X.5 (настройка осуществляется после загрузки ОС)
Общие требования для виртуальных машин: 1. маска сети должна быть одинаковой; 2. название сети должно быть одинаковым (меню => настройка => сеть параметр «Тип подключения»: Внутренняя сеть); 3. MAC-адреса должны быть разными (меню => настройка => сеть => дополнительно => Параметр MAC-адрес); 4. должен быть отключен брандмауэр (firewall) на всех режимах работы адаптера (доменный, публичный, внутренний) или на уровне службы.	
Для обеих машин: - выключить виртуальную машину; - меню => настройка => сеть => Дополнительно параметр MAC-адрес	

3. Подключить образ оптического привода, находящийся в каталоге задания.

4. На 1 вирт. машине (Server) установить базу данных (файл mssql2005expr_setup.exe)

5. Установка модуля «Главный управляющий компьютер» на 1 вирт. машине (Server) (файл gc3setup.3.84.release.9.exe) 6 Запустите программу GameClass под пользователем Manager.

6. Пропишите в настройках (Manage => System Options) клиентский компьютер по адресу 10.0.0.5 с номером, соответствующим номеру студента.

7. Подключитесь к программе под пользователем Operator.

8. На 2 вирт. машине (Client) установите клиентскую часть программы (файл gc3setup.3.84.release.9.exe) и перезагрузите систему после установки.

Обратите внимание на изменение рабочего стола и возможность вызова меню «Пуска», контекстного меню и разрешенные действия пользователя.

9. Опишите с графическим сопровождением, как осуществляется начало работы через Серверную часть программы и через Учетные записи пользователей (в поле «имя пользователя» указать фамилию проводившего работу).

Составьте отчет о выполнении практической работы.

Включите в него копии экрана пошагового выполнения задания и ответы на вопросы к практической работе.